

Práctica 3 – Auditoría y Peritaje de Sistemas

Parte I: Conceptos generales

1. Explique las razones principales para auditar sistemas y dar ejemplos de cada una.

1. COSTOS POR PÉRDIDAS DE DATOS Si la imagen es exacta, la organización aumenta las posibilidades de adaptarse y sobrevivir a un entorno cambiante. Si la imagen es inexacta, se puede incurrir en pérdidas sustanciales. Ejemplo: pérdida de cuentas corrientes, pérdida de los datos de los alumnos.

2. COSTOS POR DECISIONES INCORRECTAS La alta calidad en la toma de decisiones depende, en parte, de: • la calidad de los datos, • la calidad de las reglas de decisión que existen en los SI automatizados. La importancia de datos exactos depende del tipo de decisiones hechas por personas que tienen algún interés en la organización.

- **Alta Gerencia** → decisiones de planeamiento estratégico → probablemente acepten algunos errores en los datos
- **Gerencia Media** → decisiones de control administrativo y de control operativo → requieren datos más exactos

3. COSTOS POR ABUSO COMPUTACIONAL El promedio de pérdidas por abusos computacionales pareciera ser sustancialmente mayor que las pérdidas producidas por fraudes convencionales. Tipos de abusos: 1) hacking 2) virus 3) acceso físico ilegal 4) abuso de privilegios

4. COSTOS POR ERRORES DE COMPUTACIÓN Los costos por un error de computación pueden ser altos, en términos de: 1) pérdida de vida humana, 2) privación de libertad, 3) daño al medio ambiente.

5. VALOR DE HW, SW Y PERSONAL Recursos críticos en las organizaciones: 1) Datos - ¿qué pasa si la competencia obtiene información confidencial? 2) Hardware - ¿qué pasa si un componente crítico deja de funcionar? 3) Software - ¿qué pasa si se destruye? 4) Personal - ¿qué pasa si un profesional calificado deja la empresa?

6. MANTENIMIENTO DE PRIVACIDAD Muchos datos se recolectan sobre los individuos: impuestos, obras sociales, trabajo, residencia. Con sistemas automatizados se puede integrar y buscar información.

7. EVOLUCIÓN CONTROLADA DEL USO Se argumenta que la confiabilidad de los sistemas computarizados complejos no está garantizada. Las consecuencias de usar sistemas no confiables puede ser catastrófica. ¿Qué efectos físicos y mentales tienen las computadoras en los usuarios? Debe existir interés para evaluar y controlar la implementación de esta tecnología.

2. Para cada uno de los siguientes interesados, presente un ejemplo de cómo un mal procesamiento de información realizado por un sistema informático, puede conducir a una toma de decisiones incorrecta:

- Gerente de una empresa vinculada a la industria automotriz
- Funcionario de ARBA
- Consejo Directivo de una facultad

Gerente de empresa automotriz

- *Error:* El sistema muestra que hay stock de 500 motores, pero en realidad hay solo 50.
- *Decisión errónea:* Lanza una campaña de ventas sin poder cubrir la demanda.
- *Consecuencia:* Retrasos en entregas, clientes enojados y pérdida de imagen.

Funcionario de ARBA

- *Error:* El sistema calcula mal el impuesto inmobiliario por un bug en la fórmula.
- *Decisión errónea:* Se notifica a contribuyentes con montos mal liquidados.
- *Consecuencia:* Reclamos masivos, devolución de dinero, caos administrativo.

Consejo Directivo de una facultad

- *Error:* El sistema muestra estadísticas de egresos infladas por un fallo en cómo cuenta los títulos.
- *Decisión errónea:* Aprueban reducir la oferta de materias porque "ya se reciben muchos".

- **Consecuencia:** Menos materias, estudiantes colapsados y más demora en egresos reales.

3. ¿Qué tipo de abusos computacionales conoce? ¿Cuáles son las consecuencias de estos abusos?

HACKING Una persona logra un acceso no autorizado a un sistema de computación para leer, modificar o borrar datos o programas para discontinuar un servicio.

VIRUS Son programas que atacan a archivos ejecutables, áreas del sistema, o archivos de datos que contienen macros, para causar una disfunción en las operaciones computacionales o dañar datos y programas.

ACCESO FÍSICO ILEGAL Una persona logra un acceso físico no autorizado a facilidades del computador. Ejemplo: a una sala de cómputos o a una terminal. Como resultado, pueden causar daño físico al hardware o hacer copias no autorizadas de programas y datos

ABUSO DE PRIVILEGIOS Una persona usa privilegios, que le han sido asignados, para propósitos no autorizados. Ejemplo: hacen copias no autorizadas de los datos a los cuales se les otorgó acceso.

4. Explique al menos dos características que diferencien entre un abuso informático y otro tipo de fraude comercial.

1. Medio de ejecución:

El abuso informático usa sistemas tecnológicos o redes (ej: hackear, malware, phishing) para hacer daño o sacar ventaja, mientras que el fraude comercial puede ser más “tradicional”, como mentir sobre un producto o falsificar documentos sin necesariamente usar tecnología.

2. Objetivo y alcance:

El abuso informático suele buscar afectar sistemas, datos o información digital para robar o dañar, y puede afectar a muchas personas a la vez por la rapidez y alcance de la tecnología. En cambio, el fraude comercial generalmente apunta a engañar a un consumidor o empresa puntual en una transacción específica.

5. Describa con sus palabras que entiende por auditoría de sistemas de información.

Definición: La auditoría de sistemas de información es el proceso de recolectar y evaluar evidencia

6. Explique los cuatro objetivos de la auditoría de sistemas de información.

- 1. Preservar los activos:**
Asegurarse de que el sistema protege los recursos de la empresa (como datos, hardware, software) para que no se pierdan, roben o dañen.
- 2. Mantener la integridad de los datos:**
Que la info guardada sea completa, correcta y no se altere sin autorización. O sea, que los datos sean confiables.
- 3. Alcanzar objetivos organizacionales con eficacia:**
Ver si el sistema ayuda a que la empresa cumpla sus metas, haciendo que todo funcione como corresponde.
- 4. Usar recursos con eficiencia:**
Comprobar que el sistema no gaste de más ni desperdicie tiempo, plata o esfuerzo en su operación.

7. ¿Qué significa que la alta gerencia implemente un sistema de control interno? ¿Cómo se lleva a cabo?

La implementación de un sistema de control interno por parte de la alta gerencia significa establecer un conjunto de políticas, procedimientos y mecanismos diseñados para garantizar el cumplimiento de los objetivos organizacionales, proteger los activos, evitar errores y fraudes, y asegurar un uso eficiente de los recursos.

Este sistema se lleva a cabo mediante

- 1) separación de obligaciones,
- 2) delegación clara de autoridad y responsabilidades,
- 3) reclutamiento y entrenamiento de personal calificado,

- 4) sistema de autorizaciones,
- 5) documentos y registros adecuados,
- 6) control físico y documentación sobre los activos,
- 7) chequeos independientes de performance,
- 8) comparación periódica de activos con registros contabilizados

Parte II: Controles y riesgos de Auditoría

8. Explique por qué un control en un sistema de información es un sistema.

Un control es un sistema que previene, detecta, o corrige eventos ilegales.

Un control en un sistema de información es un sistema porque es un conjunto organizado de mecanismos que trabajan coordinadamente para prevenir, detectar y corregir errores o fraudes, asegurando así la seguridad, integridad y eficiencia del procesamiento de datos.

Lo que llamamos “password”, que es un control para controlar el acceso, si bien le damos un nombre simple, tiene todo un sistema detrás de seguridad para elegir passwords, correcta validación de passwords, almacenamiento seguro de las passwords, seguimiento en el uso indebido de passwords, etc...

9. Explique las diferencias entre un control preventivo, control detectivo, y control correctivo. Provea ejemplos para cada tipo de control.

- **Control Preventivo:**
instrucciones de cómo completar un formulario. Nota: las instrucciones no son el control.
- **Control Detectivo:**
un programa que valida datos de input, rechazando los erróneos.
- **Control Correctivo:**
un programa que detecta el ruido en comunicaciones y permite corregir datos corruptos.

10. ¿Cuál es la tarea del auditor en cuanto a los controles?

Reducir las pérdidas esperadas por eventos ilegales mediante:

- 1) controles preventivos: reducen la probabilidad que estos eventos ocurran.
- 2) controles detectivos y correctivos: reducen la cantidad de pérdidas cuando los eventos ilegales ocurren.

La tarea del auditor es determinar si los controles están ubicados y funcionan para prevenir los eventos ilegales.

11. Explique desde el punto de vista de auditoría de sistemas de información el concepto de “factorizar en subsistemas” y qué criterio(s) se aplica(n) para factorizar un sistema en subsistemas.

El primer paso para comprender un sistema complejo es particionarlo en subsistemas. Un subsistema es un componente de un sistema que: 1) realiza ciertas funciones básicas necesarias para el sistema en general, 2) le permite atender sus objetivos fundamentales. Los subsistemas son componentes lógicas y no físicas. El proceso de particionar en subsistemas se denomina factorización.

Para poder factorizar, se necesita un criterio. Criterio: La esencia de un subsistema es la función que realiza. Los auditores deben identificar primero, las principales funciones que el sistema realiza para cumplir sus objetivos. El proceso de factorización termina cuando se ha particionado el sistema en partes lo suficientemente pequeñas, de tal modo que puedan ser entendidas y evaluadas.

FORMAS DE FACTORIZACIÓN 1) funciones gerenciales - las funciones que se deben realizar para asegurar que el desarrollo, la implementación, operación y mantenimiento de los sistemas de información proceden de una forma planificada y controlada. 2) funciones de aplicación - tareas que son necesarias ejecutar para realizar un procesamiento de información confiable. Relacionado con “ciclos”.

12. Indique qué otros criterios de factorización existen.

Además de las funciones, existen otras dos guías:

ACOPLAMIENTO Cada subsistema debería ser relativamente independiente de otros subsistemas. Sistemas con poco acoplamiento son más fáciles de comprender.

COHESIÓN

Cada subsistema debe ser internamente cohesivo. Todas las actividades realizadas por el sistema apuntan a cumplir la función principal del subsistema.

13. ¿De qué manera se mide la confiabilidad de los controles?

CONFIABILIDAD DE CONTROLES Para evaluar la confiabilidad de los controles: 1) se deben identificar todos los posibles tipos de eventos que pueden ocurrir en el subsistema. 2) se deben considerar todos los eventos válidos o ilegales. Para identificar los eventos, hay que considerar las principales funciones que realiza el subsistema.

CONSIDERAR LAS PRINCIPALES FUNCIONES Para cada función: 1) analizar cómo debería realizarse 2) evaluar cómo el subsistema cumple con esa visión

normativa. Para determinar si un evento es legal o ilegal se deben considerar las transacciones que pueden ocurrir como input al subsistema. Todos los eventos en un sistema de aplicación deben surgir de una transacción

EVENTOS Y TRANSACCIONES Cuando un evento ocurre, el sistema recibe una transacción de input. Cuando la transacción se recibe como input el sistema cambia de estado. Otros cambios de estado ocurren a medida que el sistema procesa la transacción. Ejemplo: toma de pedidos. Para identificar todos los eventos que pueden ocurrir en un sistema como resultado de la transacción, se debe entender cómo el sistema procesa la transacción.

14. Identifique cuatro tipos de riesgos. Explique la naturaleza de cada uno de ellos.

RIESGOS DE LA AUDITORÍA Recordemos los objetivos de la auditoría:

- 1) salvaguardar activos
- 2) asegurar integridad de los datos
- 3) asegurar que los sistemas son efectivos
- 4) asegurar que los sistemas son eficaces Para poder cumplir con los objetivos, se debe recolectar evidencia. Para esto, se debe medir, y se podría fallar al detectar las pérdidas materiales reales o potenciales.

Definición El riesgo de auditoría es el riesgo de que un auditor fracase al detectar las pérdidas materiales reales, o potenciales, o los registros incorrectos.

- 1) **Riesgo Deseado:** el riesgo que se desea correr.
- 2) **Riesgo Inherente:** refleja la probabilidad que una pérdida material o una imputación errónea exista en algún segmento de la auditoría, antes de que sea considerada la confiabilidad de los controles internos.
- 3) **Riesgo de Control:** refleja la probabilidad que en algún segmento de la auditoría, los controles internos no prevengan, detecten o corrijan pérdidas materiales o imputaciones erróneas que puedan surgir.
- 4) **Riesgo de Detección:** refleja la probabilidad que los procedimientos de auditoría utilizados en algún segmento, fallen en detectar pérdidas materiales o imputaciones erróneas.

Parte III: Proceso de Auditoría

15. Explique brevemente el proceso de auditoría.

La auditoría de sistemas de información es el proceso de recolectar y evaluar evidencia para determinar si:

- 1) el sistema automático preserva los activos,
- 2) mantiene la integridad de los datos,
- 3) permite que los objetivos organizacionales se alcancen con eficacia,
- 4) usa los recursos con eficiencia

El proceso de auditoría consiste en:

1. **Planificar:** Definir qué se va a auditar, objetivos, alcance y recursos.
2. **Recolectar evidencia:** Revisar documentos, sistemas y entrevistar gente para juntar datos.
3. **Evaluar:** Analizar la evidencia para ver si los controles funcionan y si hay riesgos o fallas.
4. **Reportar:** Hacer un informe con los hallazgos, conclusiones y recomendaciones.
5. **Seguimiento:** Verificar que se implementen las correcciones sugeridas.

Existen diferentes procedimientos de auditoría, dependiendo de lo que se desee controlar: 1) determinar si ocurrieron pérdidas materiales o la información financiera es errónea 2) determinar la eficiencia y eficacia de las operaciones

16. Enuncie cinco tipos de procedimientos de auditoría que pueden ser usados para recolectar evidencia en una auditoría.

A fin de recolectar evidencia, para determinar si ocurrieron pérdidas materiales o la información financiera es errónea, se usan los siguientes procedimientos: 1) procedimientos para comprender los controles 2) testeo de controles 3) testeos sustantivos de detalle de transacciones 4) testeos sustantivos de detalle de balances contables 5) procedimientos de revisión analítica

17. Enumere tres tipos de testeos que se pueden realizar durante una auditoría.

testeo de controles 4) testeos sustantivos de detalle de transacciones 5) testeos sustantivos de resultados generales/balances contables

18. ¿Cómo se lleva a cabo la planificación de una auditoría? Cite diferencias entre auditoría interna y externa.

La primera etapa es la planificación. Las tareas que se realizan en la etapa de planificación varían dependiendo si es una: 1) auditoría interna 2) auditoría externa

AUDITORÍA INTERNA La etapa de planificación incluye: 1) asignar personal adecuado a las auditorías 2) obtener información del cliente 3) realizar procedimientos de revisión analíticos para comprender el negocio del cliente 4) identificar áreas de riesgo Los auditores internos se preocupan por el tamaño de las pérdidas que pudiera haber por operaciones ineficientes o ineficaces.

AUDITORÍA EXTERNA La etapa de planificación incluye: 1) investigar nuevos clientes 2) asignar personal adecuado a las auditorías 3) obtener el contrato 4) obtener información del cliente 5) realizar procedimientos de revisión analíticos para comprender el negocio del cliente 6) identificar áreas de riesgo Los auditores externos se preocupan por el tamaño de los errores en los estados financieros.

TAREAS DE PLANIFICACIÓN (TP) 1) determinar el alcance de la auditoría, 2) emitir una opinión sobre el RDA, 3) emitir una opinión sobre el RI, 4) emitir una opinión sobre el RC, 5) calcular el RD que se debe lograr para cumplir con el RDA, 6) recolectar evidencia 7) documentar evidencia

19. Describa el contenido de un informe de auditoría.

Un informe típico debería incluir: 1) una introducción que describa los objetivos de la auditoría, 2) el enfoque general utilizado, 3) un resumen de las conclusiones críticas, 4) recomendaciones para abordar las conclusiones críticas, 5) datos que respalden las conclusiones críticas.

20. Describa los cuatro tipos de opinión que un auditor puede emitir.

OPINIONES DE AUDITORÍA Los estándares en varios países requieren que la opinión sea: 1) opinión excusada: en base al trabajo realizado no se puede emitir opinión. 2) opinión adversa: se concluye que han ocurrido pérdidas materiales o que los estados financieros están distorsionados. 3) opinión con calificación: se concluye que han ocurrido pérdidas materiales o existen registros incorrectos, pero las cantidades no son considerables. 4) opinión sin calificación: el auditor considera que no han ocurrido pérdidas materiales o no existen registros incorrectos.

Parte IV: Gobernanza de TI

21. Explique el significado del concepto “Gobernanza de TI”.

La Gobernanza de TI es un subconjunto de Gobierno Corporativo de las organizaciones que se centra en los sistemas de TI, su desempeño y los riesgos asociados. **GOBIERNO CORPORATIVO** sistemas para dirigir y controlar una

corporación GOBERNANZA DE TI GOBERNANZA DE TI o trata con la relación entre el enfoque empresarial y la gestión de TI o destaca la importancia de las cuestiones de TI o promueve que las decisiones estratégicas de TI deben ser tomadas por una junta directiva corporativa METAS o asegurar que las inversiones en TI generen valor o mitigar riesgos asociados con TI

22. Explique qué es COBIT y cuáles son sus elementos.

COBIT OBJETIVOS DE CONTROL PARA INFORMACIÓN Y TECNOLOGÍA RELACIONADA (COBIT) es un conjunto de recursos que contienen toda la información que las organizaciones necesitan para adoptar un marco de gobernanza y control de TI. Fue creado por la Asociación de Auditoría y Control de Sistemas de Información

23. Explique la diferencia entre Gobernanza y Administración de TI.

DOS CONCEPTOS DIFERENTES ADMINISTRACIÓN DE TI se trata de tomar e implementar decisiones de TI GOBERNANZA DE TI se trata de quién toma las decisiones de TI o quién tiene autoridad para tomar las decisiones importantes o quién tiene información para tomar las decisiones importantes o quién es responsable por implementar las decisiones importantes

24. ¿Cuáles son los principios de COBIT?

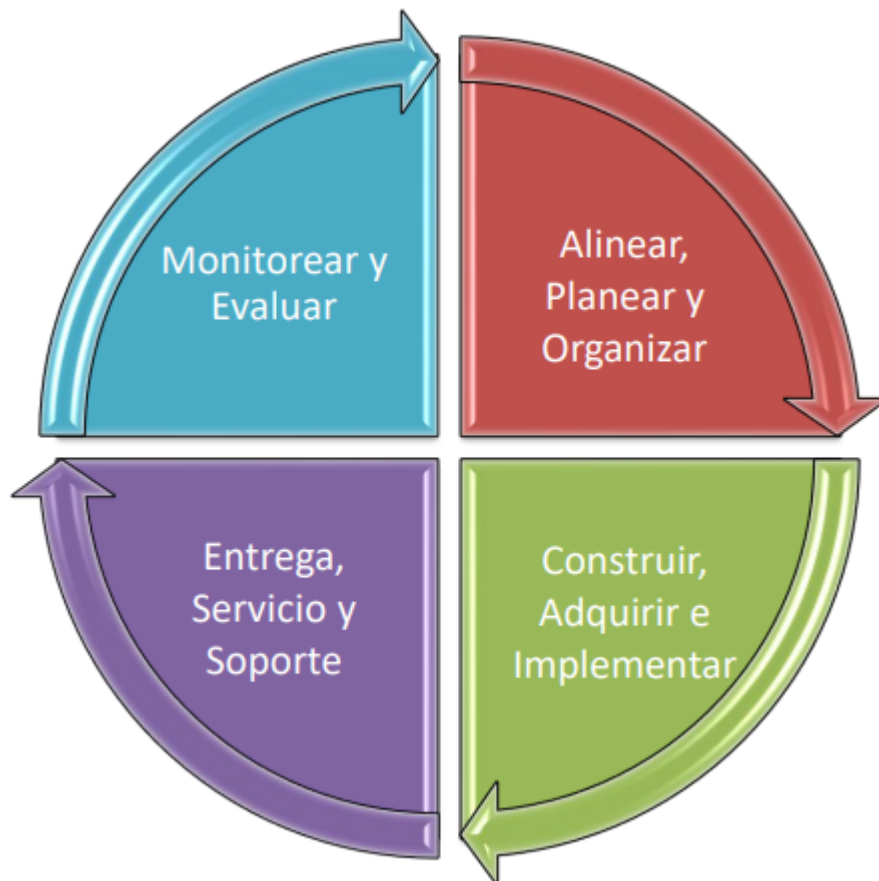
1) Satisfacer las necesidades de las partes interesadas Garantizar que las empresas aporten valor a sus partes interesadas mediante la obtención de beneficios, la optimización del uso de los recursos y la gestión de riesgos. 2) Cubrir la empresa de extremo a extremo Tener en cuenta todos los sistemas de gobernanza y administración relacionados con TI para que sean integrales y de extremo a extremo – incluyendo tanto sistemas internos como externos. 3) Aplicar un marco integrado Alinearse con otros estándares y buenas prácticas relacionadas con TI, sirviendo de marco general para la gobernanza y administración de TI empresarial. 4) Habilitar un enfoque holístico Tener en cuenta los elementos que interactúan, especificar un conjunto de habilitadores para definir un sistema integral de gobernanza y administración de TI empresarial. 5) Separar las funciones principales Establecer una distinción clara entre las funciones de gobernanza y administración.

25. Indique de qué forma organiza COBIT los procesos de TI.

Procesos de TI se dividen en 5 dominios (COBIT 5): GOBERNANZA 1) Evaluar, Dirigir y Monitorear ADMINISTRACIÓN 2) Alinear, Planear y Organizar 3) Construir, Adquirir e Implementar 4) Entrega, Servicio y Soporte 5) Monitorear y Evaluar

26. Explique cómo COBIT clasifica la administración de TI.

COBIT clasifica la Administración de TI en 4 dominios: Alinear, Planear y Organizar (APO) proporciona direcciones a la entrega de soluciones y servicios Construir, Adquirir e Implementar (BAI) provee soluciones a DSS para la entrega de servicios Entrega, Servicio y Soporte (DSS) recibe soluciones y las hace utilizables para los usuarios finales Monitorear y Evaluar (MEA) monitorea todos los procesos para asegurar que se siga la dirección provista



27. Justifique la importancia de aplicar COBIT en una organización.

Implementar COBIT (Control Objectives for Information and Related Technologies) es clave para alinear la tecnología de la información (TI) con los objetivos estratégicos del negocio. Este marco de trabajo proporciona un conjunto de mejores prácticas que permiten gestionar y gobernar los procesos de TI de manera efectiva.

Beneficios clave:

- Alineación estratégica: COBIT ayuda a que las iniciativas de TI respalden directamente los objetivos del negocio, asegurando que cada inversión en tecnología contribuya al éxito organizacional.

- Mejora de la eficiencia operativa: Al estandarizar y optimizar los procesos de TI, COBIT permite una gestión más eficiente de los recursos, reduciendo costos y mejorando el rendimiento.
- Gestión de riesgos: COBIT proporciona directrices para identificar, evaluar y mitigar los riesgos asociados con la tecnología, protegiendo así los activos críticos de la organización.
- Cumplimiento normativo: Facilita el cumplimiento de leyes y regulaciones aplicables, ayudando a evitar sanciones y mejorando la reputación corporativa.
- Transparencia y rendición de cuentas: Establece roles y responsabilidades claras, promoviendo una cultura de responsabilidad y mejorando la toma de decisiones en todos los niveles.

En resumen, aplicar COBIT permite a las organizaciones gestionar sus procesos de TI de manera alineada con sus objetivos estratégicos, optimizando recursos, mitigando riesgos y asegurando el cumplimiento normativo